Lista de verificación de controles y cumplimiento

Para completar la lista de verificación de la evaluación de controles, consulte la información proporcionada en el informe de alcance, objetivos y evaluación de riesgos. Para obtener más detalles sobre cada control, incluyendo el tipo y el propósito, consulte el documento de categorías de controles.

Luego, seleccione "sí" o "no" para responder a la pregunta:

¿Tiene Botium Toys actualmente este control implementado?

Lista de verificación de evaluación de controles

¿Sí?	¿No?	Control
	X	Privilegio mínimo
	X	Planes de recuperación ante desastres
	X	Políticas de contraseñas
	X	Segregación de funciones
X		Firewall
	X	Sistema de detección de intrusos (IDS)
	X	Copias de seguridad (Backups)
X		Software antivirus
	X	Monitoreo, mantenimiento e intervención manual para sistemas heredados
	X	Cifrado
	X	Sistema de gestión de contraseñas
X		Cerraduras (oficinas, tienda, almacén)
X		Vigilancia por televisión de circuito cerrado (CCTV)
X		Detección/prevención de incendios (alarma, sistema de rociadores, etc.)

Lista de verificación de cumplimiento

Para completar la lista de verificación de cumplimiento, consulte la información proporcionada en el informe de alcance, objetivos y evaluación de riesgos.

Luego, seleccione "sí" o "no" para responder a la pregunta:

¿Cumple actualmente Botium Toys con esta mejor práctica de cumplimiento?

Estándar de Seguridad de Datos para la Industria de Tarjeta de Pago (PCI DSS)

¿Sí?	¿No?	Mejor práctica
	X	Solo los usuarios autorizados tienen acceso a la información de las tarjetas de crédito de los clientes.
	X	La información de las tarjetas de crédito se almacena, acepta, procesa y transmite internamente, en un entorno seguro.
	X	Implementar procedimientos de cifrado de datos para asegurar mejor los puntos de contacto y los datos de las transacciones con tarjeta de crédito.
	X	Adoptar políticas seguras de gestión de contraseñas.

Reglamento General de Protección de Datos (RGPD / GDPR)

¿Sí?	¿No?	Mejor práctica
	X	Los datos de los clientes de la U.E. se mantienen privados/asegurados.
X		Existe un plan para notificar a los clientes de la U.E. en un plazo de 72 horas si sus datos se ven comprometidos o hay una brecha de seguridad.
	X	Asegurar que los datos estén debidamente clasificados e inventariados.
X		Aplicar políticas, procedimientos y procesos de privacidad para documentar y mantener los datos correctamente.

Controles de Sistema y Organización (SOC tipo 1, SOC tipo 2)

¿Sí?	¿No?	Mejor práctica
	X	Se han establecido políticas de acceso de usuarios.
	X	Los datos sensibles (PII/SPII) son confidenciales/privados.
X		La integridad de los datos asegura que la información sea consistente, completa, precisa y haya sido validada.
X		Los datos están disponibles para las personas autorizadas a acceder a ellos.

Esta sección es opcional y puede utilizarse para proporcionar un resumen de las recomendaciones al gerente de TI sobre qué controles y/o mejores prácticas de cumplimiento Botium Toys debe implementar, en función del riesgo que supondría no implementarlos a tiempo.

Recomendaciones (opcional): En esta sección, proporcione recomendaciones relacionadas con las necesidades de controles y/o cumplimiento que su gerente de TI podría comunicar a las partes interesadas para reducir los riesgos de los activos y mejorar la postura de seguridad de Botium Toys.

Recomendaciones Prioritarias para la Postura de Seguridad

Basado en la evaluación de riesgos y las brechas de cumplimiento detectadas, se recomiendan las siguientes acciones inmediatas:

1. Protección de Datos Financieros y Confidencialidad (PCI DSS y SOC)

- **Implementar Cifrado de Datos:** Es crítico utilizar cifrado para asegurar la confidencialidad de la información de tarjetas de crédito que se procesa y almacena localmente.
- **Establecer Control de Acceso de Mínimo Privilegio:** Se debe restringir el acceso para que los empleados solo puedan ver la información necesaria para sus funciones, reduciendo el riesgo de uso malintencionado de datos PII/SPII.
- **Segregación de Funciones:** Implementar este control administrativo para evitar que una sola persona tenga control total sobre procesos críticos.

2. Resiliencia y Continuidad del Negocio

- **Desarrollar Planes de Recuperación ante Desastres (DRP):** Actualmente no existen planes para asegurar la continuidad del negocio tras un incidente.
- **Implementar Copias de Seguridad (Backups) Recurrentes:** Es vital contar con respaldos de datos críticos para poder restaurar las operaciones después de un evento adverso.

3. Fortalecimiento de la Infraestructura Técnica

- **Instalar un Sistema de Detección de Intrusos (IDS):** Para detectar tráfico anómalo o posibles brechas en progreso que el firewall por sí solo no detiene.
- **Centralizar la Gestión de Contraseñas:** Implementar un sistema que exija requisitos de complejidad mínima (letras, números, caracteres especiales) para mitigar ataques de fuerza bruta.

4. Cumplimiento Legal y Mantenimiento

- **Completar el Cumplimiento del RGPD/GDPR:** Asegurar que todos los datos de clientes de la U.E. estén clasificados e inventariados correctamente.
- **Optimizar Sistemas Heredados (Legacy):** Establecer un calendario regular de monitoreo y mantenimiento manual para identificar vulnerabilidades en sistemas antiguos.